

Penetration Testing of OPC as Part of Process Control Systems

Maria B. Line¹, Martin Gilje Jaatun¹, Zi Bin Cheah²,
A.B.M. Omar Faruk², Håvard Husevåg Garnes³, and Petter Wedum³

¹ SINTEF ICT, N-7465 Trondheim, Norway
{maria.b.line,martin.g.jaatun}@sintef.no

² Kungliga Tekniska Högskolan, Stockholm, Sweden
{zbccheah,aofaruk}@kth.se

³ Google, Trondheim, Norway
{hgarnes,wedum}@google.com

Abstract. We have performed penetration testing on OPC, which is a central component in process control systems on oil installations. We have shown how a malicious user with different privileges – outside the network, access to the signalling path and physical access to the OPC server – can fairly easily compromise the integrity, availability and confidentiality of the system. Our tentative tests demonstrate that full-scale penetration testing of process control systems in offshore installations is necessary in order to sensitise the oil and gas industry to the evolving threats.

Keywords: Information Security, Process Control, Penetration Testing, OPC.

1 Introduction

Process control systems (PCS) are used to support and control a specific industrial process. The setting for the kind of system discussed in this paper is oil production on offshore installations. Traditionally, hardware and software components in such systems were proprietary; designed for use in a specific context. The current trend is heading towards commercial off-the-shelf technologies because of the goal of integrated operations, which means extensive cooperation between onshore and offshore staff, and the possibility of controlling installations completely from onshore.

This transition results in exposure to an entirely new set of security threats. Many components and applications in use were developed before this transition without any thought of making them intrusion-proof, because the access used to be more limited, both in the physical and the logical way.

With respect to security, the ideal solution would be to build all parts of a process control system from scratch, taking all new threats into account. In reality this is not achievable; economically it would be a disaster for the operators, and a set of threats relevant today may change during the period of development. Also, there is the fact that new security flaws are usually introduced when developing new systems. Hence the brand new systems would not be perfect anyway.

The more realistic solution is to add security functionality or security measures where they are needed. In order to identify where the needs are, several components and applications already in use must be analyzed in detail. This paper presents how a test network was set up to simulate a process control system, and how intrusion tests were performed towards OPC. The concept of OPC is described in the following section.

1.1 OPC – OLE for Process Control

OLE¹ for Process Control (OPC) [1] is a mechanism for exchanging process control data among numerous data sources in process control system. OPC is implemented as a client-server-architecture. The OPC server aggregates data from available control units in the system. It is capable of reading and writing values from/to these units, and offers mechanisms for interaction with these values to an OPC client. OPC is widely used in process control systems due to its stability and reliability. Also, it allows transmission of double precision real numbers, which other protocols usually do not allow without rewriting [2].

The OPC interface is defined on Microsoft's OLE/COM (where COM stands for Component Object Model) [3], and most OPC servers run on MS Windows servers, even though there exist some implementations for other operating systems, such as OpenSCADA. The OPC interface is implemented as a set of function calls to COM objects defined by the OPC server, and can be accessed by DCOM (Distributed COM) from other computers. Hence, OPC does not implement security, but makes use of the security offered by DCOM.

We have used OPC Tunneller and OPC Simulation Server from Matrikon² in our simulated process control system. The reason for choosing Matrikon is that it is a freely available and fully functioning OPC-server for use in a non-production setting. The simulation server is normally used for testing OPC connections and services before production servers are put to use. It is therefore considered to be a suitable alternative for a real OPC server.

1.2 Penetration Testing

Penetration testing is a way of evaluating the security of a system by simulating attacks by a malicious user against the system. Such testing can be performed in different ways; by running known vulnerability scanners like Nessus³ and Nmap⁴, or more as research and testing of new and unknown vulnerabilities.

Nessus is well-suited for testing systems in production, and it is low-cost. It is continuously updated with new modules for newly discovered vulnerabilities, and running Nessus gives a good indication for how secure a system is, without giving a 100% complete result, which is quite impossible to achieve in any ways.

Testing of unknown vulnerabilities requires extensive knowledge of the system in focus and is hence out of the question for our tests this time, as time and resources

¹ OLE stands for Object Linking and Embedding.

² <http://www.matrikonopc.com>

³ <http://www.nessus.org>

⁴ <http://insecure.org/nmap/>